

UNIDAD I. CONCEPTOS GENERALES DE SEGURIDAD INFORMÁTICA

ING. LIZMAYREM MÁRQUEZ





CRITERIOS DE EVALUACIÓN	PORCENTAJE
PARCIALES	30%
SEMESTRAL	33%
PROYECTOS	15%
LABORATORIOS	10%
PORTAFOLIO ESTUDIANTIL	5%
TAREAS, TRABAJO EN CLASE, EJERCICIOS CORTOS	7%

CONCEPTOS GENERALES DE SEGURIDAD
INFORMÁTICA

MECANISMOS DE SEGURIDAD, AUTENTICACIÓN
Y CONTROL DE ACCESO

SEGURIDAD EN EL CICLO DE VIDA DEL
SOFTWARE, VECTORES DE ATAQUES Y
ESTRATEGIA DE DEFENSA

ANÁLISIS DE RIESGO, PLAN DE CONTINGENCIA Y
POLÍTICA DE SEGURIDAD



UNIDAD I

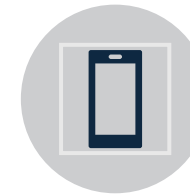
Conceptos Generales de Seguridad Informática



INTRODUCCIÓN



**CONCEPTOS DE
SEGURIDAD**



**SERVICIOS DE
SEGURIDAD**



**AMENAZAS,
VULNERABILIDADES
Y ATAQUES**

OBJETIVOS



1. Conocer y comprender los conceptos básicos sobre seguridad informática.
2. Describir los servicios básicos que garantizan la integridad, confiabilidad, disponibilidad y no repudio de la información.
3. Describir las diferentes amenazas, vulnerabilidades, ataques a los que se enfrentan los sistemas informáticos.

CUMPLIMIENTO Y NORMATIVAS

- ISO 27001 (Gestión de Seguridad de la Información)
- ISO 27002 (Controles de Seguridad)
- NIST (Instituto Nacional de Estándares y Tecnología de EE.UU)
- PCI DSS (Payment Card Industry Data Security Standard)
- GDPR (Protección de Datos en la UE)
- SOX (Sarbanes – Oxley) Ley para la transparencia financiera y auditoría.
- Ley 81 (Protección de datos personales de Panamá)



Conceptos de Seguridad

Seguridad de Información

Se orienta a proteger los activos de información sin importar su forma o estado, valiéndose de metodologías, normas, técnicas, herramientas, estructuras organizacionales, tecnología y gestión de las medidas de seguridad apropiadas en cada caso

Seguridad Informática

Abarca la protección de sistemas de información, incluyendo hardware, software, redes y datos digitales, se enfoca en la integridad, disponibilidad y confidencialidad.

Ciberseguridad

Es la protección de activos de información, a través del tratamiento de amenazas que ponen en riesgo la información que es procesada, almacenada y transportada por los sistemas de información que se encuentran interconectados.



¿Qué es la seguridad informática?

- La seguridad de la tecnología de la información (seguridad informática) constituye un amplio conjunto de medidas multidisciplinarias de protección para evitar que una red informática y sus datos sufran algún tipo de vulneración, filtración, publicación de información privada o ataque.
- La seguridad informática es la rama de la informática que se encarga de estudiar cómo preservar la confidencialidad, integridad y disponibilidad de datos y programas en sistemas de cómputo.

Seguridad en la Red

- Es una parte de la Seguridad informática que protege la infraestructura de redes y la información que viaja a través de ellas. En la seguridad de la red, podemos enfrentarnos a una serie de amenazas de atacantes, configuraciones incorrectas de la infraestructura o dispositivos habilitados para la red, o incluso de simples interrupciones.



Elementos en la Seguridad de Red

Seguridad en
diseño de redes

Detección de
intrusiones en la
red

Protegiendo el
tráfico de red

Seguridad en
redes
Inalámbricas

Herramientas de
Seguridad en la
red

TIPOS DE LA SEGURIDAD INFORMÁTICA

Seguridad de Hardware

- Se refiere a la protección propia de los dispositivos como teléfonos móviles, computadoras, tablets y dispositivos inteligentes contra los ataques que pueden comprometer su funcionamiento.

Seguridad de Software

Es la protección de los programas y aplicaciones contra los ciberataques.

Desarrollo de software seguro.

Seguridad de Red

Medidas y acciones destinadas a proteger información sensible, la cual puede ser accesible a través de internet.

Herramientas que se disponen para brindar protección a la red tenemos antivirus, firewalls, redes de acceso privadas (VPN) y sistemas de prevención de intrusiones (IPS).

TIPOS DE SEGURIDAD INFORMÁTICA

En función de lo que se quiere proteger:

- **Seguridad física:** se asocia a la protección física del sistema ante amenazas como inundaciones, incendios, robos, etc.
- **Seguridad lógica:** mecanismos que protegen la parte lógica de un sistema informático (datos, aplicaciones y sistemas operativos).

En función del momento en que tiene lugar la protección:

- **Seguridad activa:** se encarga de prevenir, detectar y evitar cualquier incidente en los sistemas informáticos antes de que se produzca (medidas preventivas). Por ejemplo, utilización de contraseñas.
- **Seguridad pasiva:** comprende todas aquellas técnicas o procedimientos necesarios para minimizar las consecuencias de un incidente de seguridad (medidas correctivas). Por ejemplo, las copias de seguridad.

SERVICIOS DE SEGURIDAD



Confidencialidad

- Es la propiedad de la información, por la que se garantiza que está accesible únicamente a personal autorizado a acceder a dicha información.

Integridad

- Se garantiza la exactitud de los datos transportados o almacenados, asegurando que no se ha producido su alteración, pérdida o destrucción, ya sea de forma accidental o intencionada, por errores de *software* o *hardware*.

Disponibilidad

- La capacidad de un servicio, un sistema o una información, a ser accesible y utilizable por los usuarios o procesos autorizados cuando éstos lo requieran.

No Repudio

- Es un servicio de seguridad que permite probar la participación de las partes en una comunicación. Existirán por tanto dos posibilidades: - No repudio en origen: El emisor no puede negar que envió porque el destinatario tiene pruebas del envío.

Autenticación

- Es el proceso de verificar la identidad de un usuario, aplicación o servicio antes de que pueda acceder a un sistema digital.



Los tres tipos de factores más comunes son:

AUTENTICACIÓN

- Algo que conoces: como una contraseña o un PIN memorizado.
- Algo que tengas: como un smartphone o una clave USB segura.
- Algo que seas: como una huella digital o un reconocimiento facial.

DIFERENCIAS ENTRE VULNERABILIDAD & AMENAZAS



Vulnerabilidad

Es una debilidad propia de un sistema que permite ser atacado y recibir un daño.

Amenaza

Es toda acción que aprovecha una vulnerabilidad para atentar contra la seguridad.

Ataque

Son acciones malintencionadas que comprometen la seguridad de sistemas, redes, datos.

AMENAZAS

- Circunstancia desfavorable que puede ocurrir y que cuando sucede tiene consecuencias negativas sobre los activos provocando su indisponibilidad, funcionamiento incorrecto o pérdida de valor. Una amenaza puede tener causas naturales, ser accidental o intencionada. Si esta circunstancia desfavorable acontece a la vez que existe una vulnerabilidad o debilidad de los sistemas o aprovechando su existencia, puede derivar en un incidente de seguridad.



TIPOS DE AMENAZAS



INTENCIONADAS

Suplantación
de la identidad
de usuario

Abuso de
privilegio de
acceso

Difusión de
software
daño

Acceso no
autorizado

Análisis de
tráfico

Destrucción de
la información

Manipulación
de los equipos

Denegación de
servicio

Robo

Ingeniería
social

Ataque
destrutivo



ERROR Y FALLAS NO INTENCIONADAS



Error de los usuarios

Error del administrador

Error de configuración

Alteración accidental de la información

Fuga de información

Errores de mantenimientos de hardware/Software

Caída del sistema por agotamiento de recursos

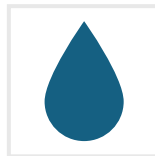
Pérdida de equipo



ORIGEN INDUSTRIAL



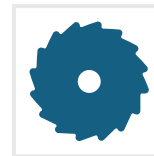
Fuego



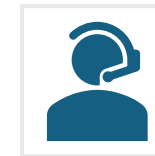
Daño por agua



Avería de origen físico o
lógico



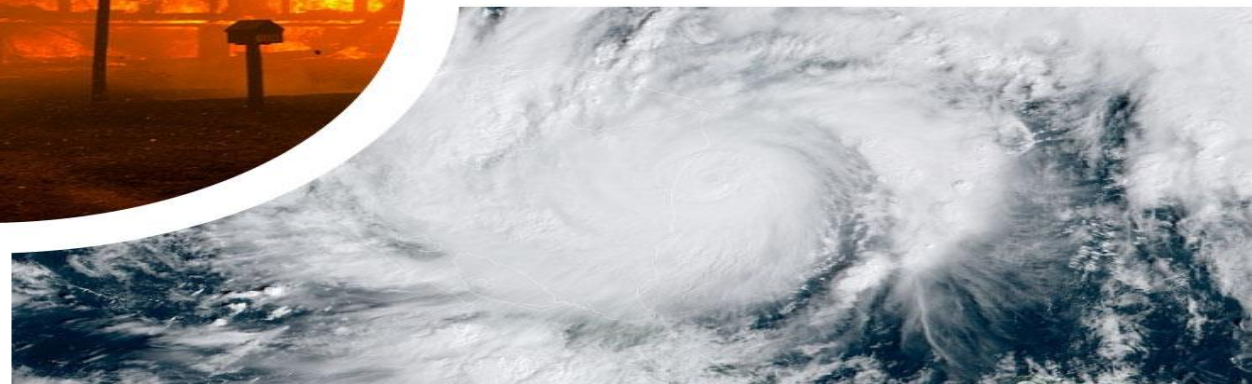
Corte de suministro
eléctrico



Fallo de los servicios de
comunicaciones



Degradación del soporte
de almacenamiento de
información



DESASTRE NATURAL

-  Fuego
-  Daño por agua
-  Desastre natural

VULNERABILIDAD

- Es una debilidad propia de un sistema que permite ser atacado y recibir un daño. Las vulnerabilidades se producen de forma habitual por una baja protección contra ataques externos, falta de actualizaciones, fallos de programación, y otras causas similares.
- A las vulnerabilidades también se las conoce como agujeros de seguridad y tienen la ventaja de que pueden ser solventadas una vez sean descubiertas.
- Una vulnerabilidad pone en riesgo los datos y sistemas de una empresa comprometiendo su integridad, privacidad y disponibilidad.



TIPOS DE VULNERABILIDADES

Buffer overflow o desbordamiento de buffer

- se da cuando las aplicaciones no controlan la cantidad de datos que copian en el buffer y que al sobrepasar el tamaño de este pueden modificar zonas de memoria contiguas afectando a los datos que albergan.

Código de carrera

- las aplicaciones o sistemas no implementan exclusiones mutuas en el acceso a recursos compartidos, como por ejemplo una variable, y varios procesos acceden a ella al mismo tiempo obteniendo valores no esperados.

Error de formato en cadenas

- cuando las aplicaciones no validan los datos de entrada que introduce el usuario a las mismas, pudiendo ejecutar por ejemplo comandos o instrucciones que pueden permitir al atacante obtener datos confidenciales o dañar el sistema.

Cross Site Scripting

- se basa en que los atacantes incrustan scripts en páginas web legítimas afectadas por esta vulnerabilidad y por las que navega el usuario. Este introduce datos como, por ejemplo, su usuario y su contraseña, pero no en la web legítima si no en la del atacante, que roba así sus datos.

Inyección SQL

- cuando no se validan los datos de entrada a formularios que se comunican con bases de datos se podría ejecutar código SQL malicioso que por ejemplo permitiera obtener datos confidenciales o corromper los datos de las tablas.

ATAQUES INFORMÁTICO

- **Un ataque:** es cualquier esfuerzo intencional para robar, exponer, alterar, deshabilitar o destruir datos, aplicaciones u otros activos a través del acceso no autorizado a una red, sistema informático o dispositivo digital.
- **Atacantes:** es cualquier entidad que podría ser persona, grupo, organización que intenta vulnerar a los sistemas, redes, aplicaciones, robar información, interrumpir servicios.



TIPOS DE ATACANTES



Black Hat

El objetivo de estas personas es lucrarse o dañar un sistema u organización.



White Hat

El objetivo de estas personas es buscar vulnerabilidades. Suelen trabajar como freelance o pertenecen a una empresa en concreto.



Grey Hat

El objetivo de estos hackers es mejorar potencialmente la seguridad de una infraestructura. Aunque la legalidad de estas acciones es cuestionable.

TIPOS DE ATAQUES INFORMÁTICOS

Ingeniería social

- Conjunto de técnicas que los delincuentes usan para engañar a los usuarios de sistemas/servicios TIC para que les faciliten datos que les aporten valor, ya sean credenciales, información sobre los sistemas, servicios instalados etc.

Denegación de servicio

- Ataque a un sistema, aplicación o dispositivo para dejarlo fuera de servicio debido a una saturación de peticiones.

Ataque de fuerza bruta

- Un ataque de fuerza bruta es un procedimiento para averiguar una contraseña que consiste en probar todas las combinaciones posibles hasta encontrar la combinación correcta.
- Los ataques por fuerza bruta, dado que utilizan el método de prueba y error, tardan mucho tiempo en encontrar la combinación correcta (hablamos en ocasiones de miles años), por esta razón, la fuerza bruta suele combinarse con un ataque de diccionario.



TIPOS Y CATEGORÍAS DE ATAQUES



Ataques de Malware

Virus
Troyanos
Ransomware
Spyware



Ataques de Ingeniería Social

Phishing
Spear Phishing
Vishing



Ataques a Redes y Sistemas

Man – in – the - Midle
Denegación de Servicio
Sniffing
Zero – Day
Sql Injection



Ataques a Contraseñas

Fuerza bruta
Ataques de Diccionario



Ataques a Dispositivos

Robo de dispositivo
USB Malicioso

CATEGORÍAS DE ATAQUES

Ransomware

- Cifra archivos y exige un rescate.

Spam

- El spam es cualquier forma de comunicación no solicitada que se envía de forma masiva (correo electrónico masivo no solicitado).

Phishing

- Técnica o tipo de ataque en el que alguien suplanta a una entidad/servicio mediante un correo electrónico o mensaje instantáneo para conseguir las credenciales o información de la tarjeta de crédito de un usuario.

Virus

- Malware que tiene como característica principal que infecta archivos ejecutables o sectores de arranque de dispositivos de almacenamiento.

Trojanos

- Malware diseñado para tener múltiples utilidades, la más común es crear una puerta trasera en el equipo infectado, para poder descargar actualizaciones y nuevas funcionalidades.

Gusanos

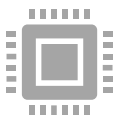
- Es un programa malicioso (o malware) que tiene como característica principal su alto grado de «dispersabilidad», es decir, lo rápidamente que se propaga.

CATEGORÍAS DE ATAQUES



Spear Phishing

Ataques dirigidos a individuos o empresas con información personalizada.



Phishing

Técnica o tipo de ataque en el que alguien suplanta a una entidad/servicio mediante un correo electrónico o mensaje instantáneo para conseguir las credenciales o información de la tarjeta de crédito de un usuario.



Vishing

Llamada telefónica



Man – in – the -Middle

Un atacante intercepta la comunicación entre dos partes para espiar o modificar los datos



Gusanos

Inserción de código malicioso en bases de datos para obtener acceso no autorizado.

CATEGORÍAS DE ATAQUES



Fuerza bruta

Un ataque de fuerza bruta es un procedimiento para averiguar una contraseña que consiste en probar todas las combinaciones posibles hasta encontrar la combinación correcta.

Los ataques por fuerza bruta, dado que utilizan el método de prueba y error, tardan mucho tiempo en encontrar la combinación correcta (hablamos en ocasiones de miles años), por esta razón, la fuerza bruta suele combinarse con un ataque de diccionario.



Ataques de diccionario

Usa lista de palabras comunes para descifrar contraseñas.